

1. Pick any one app you use daily (such as Instagram, Zomato, or PhonePe) and list 5 security measures it likely uses to protect user data.

Security measures of Instagram

No	Security Measure	How it protects users
1	Encryption	Encrypt data during transmission so attackers cannot easily read it.
2	HTTPS/TLS	Secures communication between the Instagram app and its servers.
3	Two-Factor Authentication (2FA)	Adds an extra verification step when someone tries to log in.
4	Password Protection	Passwords are securely stored using hashing rather than being kept as plain text.
5	Login & Suspicious Activity Detection	Detects unusual login locations, devices or behaviour and may alert the user or require additional verification.

2. Choose the NIST Cybersecurity Framework, ISO 27001, or CIS Controls. For each of the 5 security measures you listed in the previous task, map it to the most relevant category or control in your chosen framework.

I would use NIST Cybersecurity Framework security measures

No	Security measure Instagram likely uses	NIST CSF category	How it relates

1	Encryption of user data	Protect – Data Security	Encryption helps protect user data both when stored and when transmitted.
2	Multi-Factor Authentication (MFA)	Protect – Identity management, Authentication and Access control	MFA adds an extra layer of verification to prevent unauthorized account access.
3	Firewalls and network security controls	Protect – Platform Security	Network security controls help protect systems and services from unauthorized network activity.
4	Login monitoring and suspicious-login detection	Detect – Continuous Monitoring	Monitoring login activity can help identify unusual locations, devices or behaviour.
5	Security alerts and incident response	Response – Incident Management	When suspicious activity or a security incident occurs response procedures help contain and manage it.

3. Given this scenario: A new food delivery app wants to prevent unauthorized access, protect payment info, and ensure customer privacy. Select 3 controls from the CIS Controls framework that would address these concerns and explain how each control helps.

- For a food delivery app these 3 CIS controls would be especially useful:

CIS Control	How it helps
1. Inventory and Control of Enterprise Assets	Keeps track of all servers, computers, databases, cloud systems and other devices used by the app. This helps prevent unauthorized devices or systems from accessing sensitive customer data.
3. Data Protection	Protects sensitive information such as customer details, addresses, passwords and payment information. Measures can include encryption, access restrictions and secure data storage.
6. Access Control Management	Ensures that only authorized users and employees can access systems and data using strong authentication, least-privilege access and regularly reviewing user accounts helps prevent unauthorized access.

- In simple way,
- Control-1 Know what systems you have and secure them.
- Control-3 Protect customer and payment data.
- Control-6 Make sure only authorized people can access it.

4. Create a comparison table with three columns (NIST, ISO 27001, CIS Controls) and list 3 unique features or strengths of each framework based on your research.

- Comparison of NIST, ISO 27001 and CIS Controls**

NIST	ISO 27002	CIS Controls
1. Risk-based approach – Helps organizations identify, assess and manage cybersecurity risks according to their specific needs.	1. Internationally recognized isms – provides requirements for building and maintaining an Information Security Management System (ISMS), making it suitable for organizations worldwide.	1. Prioritized and practical – provides specific, actionable security safeguards focused on defending against common cyberattacks.
2. Flexible framework – Can be adapted to organizations of different sizes, industries and security maturity levels.	2. Certifications – Organizations can demonstrate conformity through ISO/IEC 27001 certification which can increase customer and business trust.	2. Implementation Groups – IG1,IG2 and IG3 allow organizations to prioritize controls based on their resources, risk and security maturity.
3. Strong cybersecurity lifecycle – Supports activities such as identifying, protecting, detecting, responding to and recovering from cybersecurity risks.	3. Holistic cybersecurity management – Covers people, policies, technology, risk management and continual improvement rather than focusing only on technical controls.	3. Measureable and actionable – safeguards are designed to be specific and measureable making CIS useful for security teams that need clear technical actions.

- 5. Use ChatGPT or another AI tool to generate a checklist of 5 security actions a small e-commerce startup should take according to the ISO 27001 framework. Copy the AI's response and briefly comment on whether you agree with each item and why.**

AI-Generated Checklist

- ☐ 1. Identify and manage information security risks — create an information security risk assessment covering customer data, payment information, employee accounts, systems, and other important assets.
- ☐ 2. Implement strong access controls — Use unique user accounts, strong passwords, multi-factor authentication (MFA), and least-privilege access so employees only access the information they need.
- ☐ 3. Protect customer and business data — Encrypt sensitive information, especially customer and payment-related data, both when stored and when transmitted over networks.
- ☐ 4. Maintain backups and an incident response plan — regularly back up important business data and establish procedures for detecting, reporting, responding to, and recovering from security incidents.
- ☐ 5. Train employees and regularly review security — provide security awareness training to employees and periodically review security controls, risks, and policies to ensure they remain effective.

My Comments

1. Identify and manage information security risks — Agree.
I agree because ISO 27001 is based on a risk-management approach. A small e-commerce company needs to understand what could threaten customer information, payment systems, and business operations before deciding which security controls are necessary.

2. Implement strong access controls — Agree.

I agree because limiting access reduces the chance of unauthorized users accessing sensitive customer or business information. MFA and least-privilege access are particularly useful for protecting administrator and employee accounts.

3. Protect customer and business data — Agree.

I agree because e-commerce companies handle sensitive information. Encryption helps protect data if it is intercepted during transmission or accessed without authorization.

4. Maintain backups and an incident response plan — Agree.

I agree because backups help the startup recover from incidents such as ransomware, accidental deletion, or system failure. An incident response plan also helps employees know what to do when a security incident occurs.

5. Train employees and regularly review security — Agree.

I agree because employees can accidentally cause security incidents through phishing, weak passwords, or improper handling of data. Regular training and reviews help maintain security awareness and continuously improve the organization's information security management system (ISMS).